

ISO/IEC 27001:2022

Annex A Compliance Audit Report

Acme Corporation

13.4%	0	47	17
WEIGHTED COMPLIANCE	CONTROLS PASSED	CONTROLS FAILED	HIGH RISKS OPEN

Weighted compliance against assessed Annex A controls



Report date	08 August 2026
Assessment timestamp	2026-08-08 01:18:06 UTC
Target system	WS-FIN-014
Operating system	Microsoft Windows 10 Pro
Framework	ISO/IEC 27001:2022 Annex A (93 controls)
Assessment coverage	50.5% of Annex A controls
Maturity rating	Initial - critical exposure
Prepared by	Information Security Team
Classification	CONFIDENTIAL - Internal use only

Scope and limitations

Automated point-in-time technical assessment of a single host.

1. Executive Summary

This report presents the results of an automated gap analysis of WS-FIN-014 against all 93 controls of ISO/IEC 27001:2022 Annex A. Configuration telemetry was collected from the target system and evaluated against a defined security baseline.

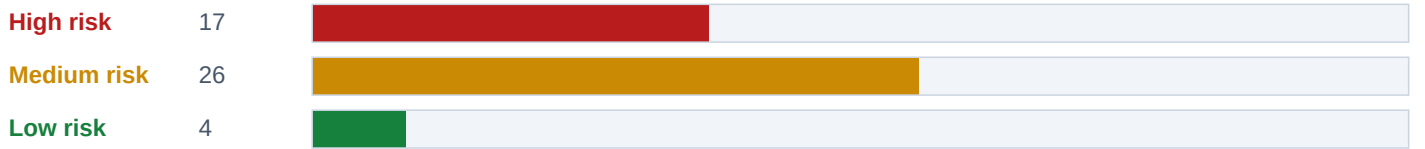
Of the 93 Annex A controls, 47 were assessed using technical evidence. 0 are fully implemented, 10 are partially implemented and 37 are not implemented. A further 46 controls are organisational or procedural in nature and require documented auditor attestation, and 0 could not be evaluated because the required telemetry was not present in the submitted dataset.

The resulting weighted compliance score is 13.4% (unweighted pass rate 0.0%), placing the system in the 'Initial - critical exposure' band. Scoring weights each control by the severity of its associated risk (High 5, Medium 3, Low 1) so that a failure of a critical control depresses the score more than a failure of a minor one.

Assessment coverage was 50.5% - that is, 47 of the 93 Annex A controls produced a definitive verdict from the evidence available.

Open risk profile

17 high, 26 medium and 4 low risk findings are currently open. High risk findings represent controls whose failure could directly lead to loss of confidentiality, integrity or availability of information assets and should be treated as the immediate remediation priority.



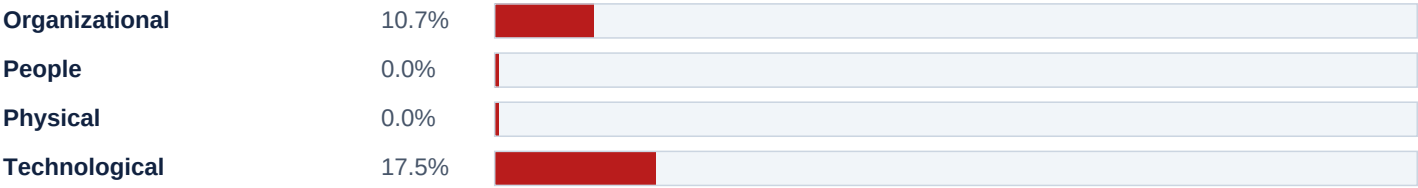
Status distribution

Status	Controls	Meaning
PASS	0	All configured technical checks satisfied
PARTIAL	10	Some checks satisfied - control partially effective
FAIL	37	No checks satisfied - control not effective
MANUAL	46	Procedural control awaiting documented attestation
NO_DATA	0	Required telemetry absent from the submitted dataset
N/A	0	Explicitly scoped out of this assessment

2. Compliance by Annex A Theme

Annex A of ISO/IEC 27001:2022 organises its 93 controls into four themes. The table below shows how the target system performs within each.

Theme	Total	Pass	Partial	Fail	Manual	No data	Compliance
Organizational	37	0	3	15	19	0	10.7%
People	8	0	0	1	7	0	0.0%
Physical	14	0	0	4	10	0	0.0%
Technological	34	0	7	17	10	0	17.5%



Highest impact open findings

Control	Title	Status	Finding
A.5.12	Classification of information	FAIL	Failed: Classification labelling technology enabled
A.5.15	Access control	FAIL	Failed: Guest account disabled; Local admin group is minimal; No shares grant..
A.5.16	Identity management	FAIL	Failed: No accounts dormant for 90+ days; Default Administrator account renam
A.5.18	Access rights	FAIL	Failed: No accounts flagged 'password never expires'; No stale accounts retain..
A.5.30	ICT readiness for business continuity	FAIL	Failed: Backup solution configured Not collected: 1 check(s)
A.5.34	Privacy and protection of PII	FAIL	Failed: Data loss prevention active; PII at rest protected by disk encryption
A.6.7	Remote working	FAIL	Failed: Full-disk encryption enabled on the device; Managed VPN client present
A.7.9	Security of assets off-premises	FAIL	Failed: Device encrypted for off-premises use; TPM present to protect encryptio
A.8.2	Privileged access rights	FAIL	Failed: Local administrators <= 3; LAPS deployed for local admin passwords; Cr
A.8.3	Information access restriction	FAIL	Failed: No file shares open to 'Everyone'; Guest account disabled; Anonymous s
A.8.8	Management of technical vulnerabilities	FAIL	Failed: No missing critical / security updates; Patched within the last 35 days; ..
A.8.9	Configuration management	FAIL	Failed: Secure Boot enabled; SMBv1 removed; Telnet client/server not installed;

3. Annex A Control Register

Complete assessment result for every ISO/IEC 27001:2022 Annex A control. 'Mode' indicates whether the control was evaluated automatically from telemetry, by auditor attestation, or a combination of both.

Control	Title	Theme	Mode	Status	Risk	Checks
A.5.1	Policies for information security	Organizational	Manual	MANUAL	High	-
A.5.2	Information security roles and responsibilities	Organizational	Manual	MANUAL	High	-
A.5.3	Segregation of duties	Organizational	Hybrid	FAIL	Medium	0/1
A.5.4	Management responsibilities	Organizational	Manual	MANUAL	Medium	-
A.5.5	Contact with authorities	Organizational	Manual	MANUAL	Low	-
A.5.6	Contact with special interest groups	Organizational	Manual	MANUAL	Low	-
A.5.7	Threat intelligence	Organizational	Hybrid	FAIL	Medium	0/1
A.5.8	Information security in project management	Organizational	Manual	MANUAL	Medium	-
A.5.9	Inventory of information and other associated assets	Organizational	Hybrid	PARTIAL	Medium	1/3
A.5.10	Acceptable use of information and other associated assets	Organizational	Hybrid	FAIL	Medium	0/2
A.5.11	Return of assets	Organizational	Manual	MANUAL	Medium	-
A.5.12	Classification of information	Organizational	Hybrid	FAIL	High	0/1
A.5.13	Labelling of information	Organizational	Hybrid	FAIL	Medium	0/1
A.5.14	Information transfer	Organizational	Hybrid	PARTIAL	Medium	1/3
A.5.15	Access control	Organizational	Hybrid	FAIL	High	0/3
A.5.16	Identity management	Organizational	Hybrid	FAIL	High	0/2
A.5.17	Authentication information	Organizational	Automated	PARTIAL	Medium	1/8
A.5.18	Access rights	Organizational	Hybrid	FAIL	High	0/2
A.5.19	Information security in supplier relationships	Organizational	Manual	MANUAL	Medium	-
A.5.20	Addressing information security within supplier agreements	Organizational	Manual	MANUAL	Medium	-
A.5.21	Managing information security in the ICT supply chain	Organizational	Manual	MANUAL	Medium	-
A.5.22	Monitoring, review and change management of supplier serv..	Organizational	Manual	MANUAL	Medium	-
A.5.23	Information security for use of cloud services	Organizational	Manual	MANUAL	High	-
A.5.24	Information security incident management planning and pre..	Organizational	Manual	MANUAL	High	-
A.5.25	Assessment and decision on information security events	Organizational	Hybrid	FAIL	Medium	0/1
A.5.26	Response to information security incidents	Organizational	Manual	MANUAL	High	-
A.5.27	Learning from information security incidents	Organizational	Manual	MANUAL	Medium	-
A.5.28	Collection of evidence	Organizational	Hybrid	FAIL	Medium	0/2
A.5.29	Information security during disruption	Organizational	Manual	MANUAL	Medium	-
A.5.30	ICT readiness for business continuity	Organizational	Hybrid	FAIL	High	0/2
A.5.31	Legal, statutory, regulatory and contractual requirements	Organizational	Manual	MANUAL	Medium	-
A.5.32	Intellectual property rights	Organizational	Hybrid	FAIL	Low	0/1
A.5.33	Protection of records	Organizational	Hybrid	FAIL	Medium	0/2
A.5.34	Privacy and protection of PII	Organizational	Hybrid	FAIL	High	0/2
A.5.35	Independent review of information security	Organizational	Manual	MANUAL	Medium	-
A.5.36	Compliance with policies, rules and standards for information	Organizational	Hybrid	FAIL	Medium	0/2
A.5.37	Documented operating procedures	Organizational	Manual	MANUAL	Low	-
A.6.1	Screening	People	Manual	MANUAL	Medium	-
A.6.2	Terms and conditions of employment	People	Manual	MANUAL	Medium	-
A.6.3	Information security awareness, education and training	People	Manual	MANUAL	High	-
A.6.4	Disciplinary process	People	Manual	MANUAL	Low	-
A.6.5	Responsibilities after termination or change of employment	People	Manual	MANUAL	Medium	-
A.6.6	Confidentiality or non-disclosure agreements	People	Manual	MANUAL	Medium	-
A.6.7	Remote working	People	Hybrid	FAIL	High	0/3

Control	Title	Theme	Mode	Status	Risk	Checks
A.6.8	Information security event reporting	People	Manual	MANUAL	Medium	-
A.7.1	Physical security perimeters	Physical	Manual	MANUAL	Medium	-
A.7.2	Physical entry	Physical	Manual	MANUAL	Medium	-
A.7.3	Securing offices, rooms and facilities	Physical	Manual	MANUAL	Low	-
A.7.4	Physical security monitoring	Physical	Manual	MANUAL	Medium	-
A.7.5	Protecting against physical and environmental threats	Physical	Manual	MANUAL	Medium	-
A.7.6	Working in secure areas	Physical	Manual	MANUAL	Low	-
A.7.7	Clear desk and clear screen	Physical	Hybrid	FAIL	Medium	0/2
A.7.8	Equipment siting and protection	Physical	Manual	MANUAL	Low	-
A.7.9	Security of assets off-premises	Physical	Hybrid	FAIL	High	0/2
A.7.10	Storage media	Physical	Hybrid	FAIL	Medium	0/2
A.7.11	Supporting utilities	Physical	Manual	MANUAL	Medium	-
A.7.12	Cabling security	Physical	Manual	MANUAL	Low	-
A.7.13	Equipment maintenance	Physical	Hybrid	FAIL	Low	0/1
A.7.14	Secure disposal or re-use of equipment	Physical	Manual	MANUAL	Medium	-
A.8.1	User end point devices	Technological	Automated	PARTIAL	Medium	1/4
A.8.2	Privileged access rights	Technological	Automated	FAIL	High	0/4
A.8.3	Information access restriction	Technological	Automated	FAIL	High	0/3
A.8.4	Access to source code	Technological	Manual	MANUAL	Medium	-
A.8.5	Secure authentication	Technological	Automated	PARTIAL	Medium	1/5
A.8.6	Capacity management	Technological	Automated	FAIL	Low	0/2
A.8.7	Protection against malware	Technological	Automated	PARTIAL	Medium	1/5
A.8.8	Management of technical vulnerabilities	Technological	Automated	FAIL	High	0/4
A.8.9	Configuration management	Technological	Automated	FAIL	High	0/5
A.8.10	Information deletion	Technological	Hybrid	FAIL	Medium	0/1
A.8.11	Data masking	Technological	Manual	MANUAL	Medium	-
A.8.12	Data leakage prevention	Technological	Automated	FAIL	High	0/3
A.8.13	Information backup	Technological	Automated	FAIL	High	0/5
A.8.14	Redundancy of information processing facilities	Technological	Hybrid	FAIL	Medium	0/1
A.8.15	Logging	Technological	Automated	PARTIAL	Medium	1/8
A.8.16	Monitoring activities	Technological	Automated	FAIL	High	0/3
A.8.17	Clock synchronization	Technological	Automated	FAIL	Medium	0/3
A.8.18	Use of privileged utility programs	Technological	Automated	FAIL	High	0/3
A.8.19	Installation of software on operational systems	Technological	Automated	FAIL	Medium	0/3
A.8.20	Networks security	Technological	Automated	PARTIAL	Medium	1/5
A.8.21	Security of network services	Technological	Automated	PARTIAL	Medium	1/5
A.8.22	Segregation of networks	Technological	Hybrid	FAIL	Medium	0/1
A.8.23	Web filtering	Technological	Automated	FAIL	Medium	0/2
A.8.24	Use of cryptography	Technological	Automated	PARTIAL	Medium	1/5
A.8.25	Secure development life cycle	Technological	Manual	MANUAL	Medium	-
A.8.26	Application security requirements	Technological	Manual	MANUAL	Medium	-
A.8.27	Secure system architecture and engineering principles	Technological	Manual	MANUAL	Medium	-
A.8.28	Secure coding	Technological	Manual	MANUAL	Medium	-
A.8.29	Security testing in development and acceptance	Technological	Manual	MANUAL	Medium	-
A.8.30	Outsourced development	Technological	Manual	MANUAL	Low	-
A.8.31	Separation of development, test and production environments	Technological	Manual	MANUAL	Medium	-
A.8.32	Change management	Technological	Hybrid	FAIL	High	0/1
A.8.33	Test information	Technological	Manual	MANUAL	Low	-
A.8.34	Protection of information systems during audit testing	Technological	Hybrid	FAIL	Low	0/1

4. Remediation Roadmap

Findings are prioritised by risk level and grouped into delivery phases. Each entry lists the specific checks that failed and the technical steps required to close the gap. Phase 1 items should be scheduled immediately.

#	Control	Title	Risk	Status	Target
1	A.5.12	Classification of information	High	FAIL	0-30 days
2	A.5.15	Access control	High	FAIL	0-30 days
3	A.5.16	Identity management	High	FAIL	0-30 days
4	A.5.18	Access rights	High	FAIL	0-30 days
5	A.5.30	ICT readiness for business continuity	High	FAIL	0-30 days
6	A.5.34	Privacy and protection of PII	High	FAIL	0-30 days
7	A.6.7	Remote working	High	FAIL	0-30 days
8	A.7.9	Security of assets off-premises	High	FAIL	0-30 days
9	A.8.12	Data leakage prevention	High	FAIL	0-30 days
10	A.8.13	Information backup	High	FAIL	0-30 days
11	A.8.16	Monitoring activities	High	FAIL	0-30 days
12	A.8.18	Use of privileged utility programs	High	FAIL	0-30 days
13	A.8.2	Privileged access rights	High	FAIL	0-30 days
14	A.8.3	Information access restriction	High	FAIL	0-30 days
15	A.8.32	Change management	High	FAIL	0-30 days
16	A.8.8	Management of technical vulnerabilities	High	FAIL	0-30 days
17	A.8.9	Configuration management	High	FAIL	0-30 days
18	A.5.1	Policies for information security	High	MANUAL	90-180 days
19	A.5.2	Information security roles and responsibilities	High	MANUAL	90-180 days
20	A.5.23	Information security for use of cloud services	High	MANUAL	90-180 days
21	A.5.24	Information security incident management planning and preparation	High	MANUAL	90-180 days
22	A.5.26	Response to information security incidents	High	MANUAL	90-180 days
23	A.6.3	Information security awareness, education and training	High	MANUAL	90-180 days
24	A.5.10	Acceptable use of information and other associated assets	Medium	FAIL	30-90 days
25	A.5.13	Labelling of information	Medium	FAIL	30-90 days
26	A.5.25	Assessment and decision on information security events	Medium	FAIL	30-90 days
27	A.5.28	Collection of evidence	Medium	FAIL	30-90 days
28	A.5.3	Segregation of duties	Medium	FAIL	30-90 days
29	A.5.33	Protection of records	Medium	FAIL	30-90 days
30	A.5.36	Compliance with policies, rules and standards for information securi	Medium	FAIL	30-90 days
31	A.5.7	Threat intelligence	Medium	FAIL	30-90 days
32	A.7.10	Storage media	Medium	FAIL	30-90 days
33	A.7.7	Clear desk and clear screen	Medium	FAIL	30-90 days
34	A.8.10	Information deletion	Medium	FAIL	30-90 days
35	A.8.14	Redundancy of information processing facilities	Medium	FAIL	30-90 days
36	A.8.17	Clock synchronization	Medium	FAIL	30-90 days
37	A.8.19	Installation of software on operational systems	Medium	FAIL	30-90 days
38	A.8.22	Segregation of networks	Medium	FAIL	30-90 days
39	A.8.23	Web filtering	Medium	FAIL	30-90 days
40	A.5.14	Information transfer	Medium	PARTIAL	30-90 days

5. Technical Remediation Detail

A.5.12 - Classification of information	High risk FAIL
<i>Failed: Classification labelling technology enabled</i> - Define a classification scheme (e.g. Public / Internal / Confidential / Restricted) with handling rules. - Deploy sensitivity labels (Microsoft Purview Information Protection or equivalent). - Train users on selecting the right label and audit label usage.	
A.5.15 - Access control	High risk FAIL
<i>Failed: Guest account disabled; Local admin group is minimal; No shares granted to 'Everyone'</i> - Disable the built-in Guest account and any generic shared logins. - Remove standing local administrator rights; grant on a role basis only. - Replace 'Everyone' share permissions with specific security groups. - Document and enforce a formal access control policy based on least privilege.	
A.5.16 - Identity management	High risk FAIL
<i>Failed: No accounts dormant for 90+ days; Default Administrator account renamed</i> - Disable accounts with no logon in 90 days and delete after a defined retention period. - Rename the built-in Administrator account and create a decoy with no privileges. - Automate provisioning/deprovisioning from the HR system of record. - Recertify all identities at least every 6 months.	
A.5.18 - Access rights	High risk FAIL
<i>Failed: No accounts flagged 'password never expires'; No stale accounts retaining access</i> - Clear the 'password never expires' flag except for documented, vaulted service accounts. - Run a formal access recertification campaign with owner sign-off every 6 months. - Revoke all access within 24 hours of termination and evidence the revocation.	
A.5.30 - ICT readiness for business continuity	High risk FAIL
<i>Failed: Backup solution configured</i> - Define RTO and RPO per service and design backup frequency to meet them. - Configure and verify a working backup job on every in-scope system. - Perform and document a full restore test at least every 6 months.	
A.5.34 - Privacy and protection of PII	High risk FAIL
<i>Failed: Data loss prevention active; PII at rest protected by disk encryption</i> - Map where PII is stored, processed and transmitted, and record the lawful basis. - Enable DLP policies that detect and block unauthorised PII egress. - Ensure full-disk encryption on every device that may hold PII. - Define and test the data subject request and breach notification workflow.	
A.6.7 - Remote working	High risk FAIL
<i>Failed: Full-disk encryption enabled on the device; Managed VPN client present; Screen lock after 15 minutes or less</i> - Enable BitLocker (or equivalent) on every mobile and remote-working device. - Require an always-on or managed VPN for access to internal resources. - Enforce a 10-15 minute screen lock with password resume. - Publish a remote working policy covering home networks, public Wi-Fi and physical security.	

A.7.9 - Security of assets off-premises**High risk | FAIL***Failed: Device encrypted for off-premises use; TPM present to protect encryption keys*

- Enable BitLocker with TPM (plus PIN for high-risk roles) on all portable devices.
- Register off-site assets and record the responsible custodian.
- Enable remote lock and wipe through the MDM platform.
- Instruct users never to leave devices unattended in vehicles or public spaces.

A.8.12 - Data leakage prevention**High risk | FAIL***Failed: DLP policy active; Removable media egress controlled; Network protection / egress filtering on*

- Deploy endpoint and cloud DLP policies targeting your classified data types.
- Restrict removable media and cloud sync clients for sensitive endpoints.
- Enable Defender Network Protection and block known exfiltration destinations.
- Start DLP in audit mode, tune, then move to block.

A.8.13 - Information backup**High risk | FAIL***Failed: Backup configured; Backups encrypted; Off-site or immutable copy held*

- Implement the 3-2-1-1 rule: 3 copies, 2 media types, 1 off-site, 1 immutable/offline.
- Schedule backups to meet the defined RPO and alert on job failure.
- Encrypt backup data at rest and in transit; protect the backup credentials separately.
- Perform and document a restore test every 6 months.

A.8.16 - Monitoring activities**High risk | FAIL***Failed: Log forwarding to SIEM / central collector; EDR sensor installed and reporting; Cloud-delivered detection enabled*

- Configure Windows Event Forwarding or a SIEM agent on every in-scope host.
- Deploy an EDR product with alerting routed to a monitored queue.
- Define detection use cases and alert thresholds for your top risks.
- Document who monitors alerts and the response time expectation.

A.8.18 - Use of privileged utility programs**High risk | FAIL***Failed: Application control (AppLocker/WDAC) enforcing; PowerShell activity logged; Remote Registry service not running*

- Enforce AppLocker or WDAC policies restricting administrative and hacking utilities.
- Enable PowerShell Constrained Language Mode for non-administrators.
- Disable the Remote Registry service unless a documented need exists.
- Log and review every use of privileged utilities.

A.8.2 - Privileged access rights**High risk | FAIL***Failed: Local administrators <= 3; LAPS deployed for local admin passwords; Credential Guard protecting privileged credentials; Built-in Administrator renamed*

- Remove standing local admin rights; use separate admin accounts or JIT elevation (PIM).
- Deploy Windows LAPS to randomise and rotate local administrator passwords.
- Enable Credential Guard (VBS) to block credential theft.
- Rename the built-in Administrator account and audit its use.
- Log and review all privileged session activity.

A.8.3 - Information access restriction**High risk | FAIL***Failed: No file shares open to 'Everyone'; Guest account disabled; Anonymous share enumeration blocked*

- Replace 'Everyone' ACLs with least-privilege security groups on all shares.
- Disable the Guest account and anonymous access.
- Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to Enabled.
- Review folder permissions against data classification annually.

A.8.32 - Change management**High risk | FAIL***Failed: No pending reboot leaving changes half-applied*

- Operate a change management process with risk assessment, approval, testing and rollback plans.
- Complete pending reboots in a controlled window so changes take effect.
- Record emergency changes retrospectively within an agreed timeframe.
- Review change records for unauthorised changes periodically.

A.8.8 - Management of technical vulnerabilities**High risk | FAIL***Failed: No missing critical / security updates; Patched within the last 35 days; OS still receiving vendor updates; Automatic updates enabled*

- Install all outstanding critical and security updates immediately.
- Define patch SLAs (critical 7 days, high 14 days, others 35 days) and measure against them.
- Enable automatic updates or an equivalent managed patching service (WSUS/Intune/SCCM).
- Upgrade or decommission any operating system past end-of-support.
- Run authenticated vulnerability scans monthly and track findings to closure.

A.8.9 - Configuration management**High risk | FAIL***Failed: Secure Boot enabled; SMBv1 removed; Telnet client/server not installed; Baseline drift within tolerance; UAC enabled*

- Adopt a documented hardening baseline (CIS Benchmark or Microsoft Security Baseline).
- Enable Secure Boot in UEFI firmware.
- Remove the SMB 1.0/CIFS and Telnet Windows features.
- Deploy the baseline via GPO or Intune and monitor drift continuously.
- Require change approval before deviating from the baseline.

A.5.10 - Acceptable use of information and other associated assets**Medium risk | FAIL***Failed: Removable storage restricted; Application control enforced*

- Publish an Acceptable Use Policy and capture signed acknowledgement from every user.
- Enforce removable-media restrictions via Group Policy or Intune device control.
- Deploy AppLocker or WDAC in enforce mode to restrict unapproved applications.

A.5.13 - Labelling of information**Medium risk | FAIL***Failed: Automatic / mandatory labelling active*

- Configure mandatory labelling so documents and email cannot be saved or sent unlabelled.
- Apply visual markings (headers, footers, watermarks) driven by the label.
- Extend labelling to physical media and printed output.

A.5.25 - Assessment and decision on information security events**Medium risk | FAIL***Failed: Events forwarded to a central platform / SIEM*

- Forward Windows event logs to a SIEM or central collector.
- Define triage criteria that turn an event into a classified incident.
- Record the assessment decision and rationale for every escalated event.

A.5.28 - Collection of evidence**Medium risk | FAIL***Failed: Security log retained at least 90 days; Security log sized at least 1 GB*

- Increase the Security event log to 1 GB or more and set retention to 90+ days.
- Archive logs to immutable/WORM storage so they cannot be altered.
- Document a chain-of-custody procedure and identify a forensics provider in advance.

A.5.3 - Segregation of duties

Medium risk | FAIL

- Failed: No more than 3 local administrator accounts*
- Map high-risk activities (approve, execute, review) and ensure no single account holds all three.
 - Reduce standing local administrator membership; use just-in-time elevation.
 - Where separation is impossible, add compensating monitoring and document the exception.

A.5.33 - Protection of records

Medium risk | FAIL

- Failed: Log records retained per schedule; Backup copies of records encrypted*
- Publish a retention schedule stating how long each record type is kept and why.
 - Encrypt backups and apply immutability / legal-hold where records are regulated.
 - Restrict deletion rights on record repositories and log all deletions.

A.5.36 - Compliance with policies, rules and standards for information security

Medium risk | FAIL

- Failed: Operating system is vendor-supported; Configuration drift from baseline is minimal*
- Run automated configuration compliance scans (this tool, SCM, Intune compliance policies).
 - Upgrade or isolate any system running an unsupported operating system.
 - Report compliance metrics to management on a fixed cadence.

A.5.7 - Threat intelligence

Medium risk | FAIL

- Failed: Cloud-delivered threat intelligence enabled*
- Enable cloud-delivered protection / reputation services on endpoint security tooling.
 - Subscribe to strategic, tactical and operational threat feeds relevant to your sector.
 - Define who reviews intelligence, how often, and how it triggers action.

Appendix A - Telemetry Evidence

Extract of the configuration parameters ingested for this assessment. These values constitute the technical evidence underpinning the automated results.

Parameter	Observed value
asset.asset_owner	(not collected)
asset.asset_tag	(not collected)
asset.data_classification_labels_enabled	False
asset.dlp_enabled	False
asset.installed_software	TeamViewer 13, uTorrent, Adobe Reader XI
asset.installed_software_count	147
asset.mdm_enrolled	False
asset.unauthorized_software	TeamViewer 13, uTorrent, AnyDesk, Advanced IP Scanner
asset.unauthorized_software_count	4
backup.backup_configured	False
backup.backup_encrypted	False
backup.backup_product	(not collected)
backup.last_backup_days	(not collected)
backup.last_backup_result	(not collected)
backup.offsite_or_immutable	False
backup.restore_tested_days	(not collected)
backup.shadow_copies_enabled	False
backup.system_restore_enabled	False
capacity.cpu_load_pct	74
capacity.memory_free_pct	7.1
capacity.memory_total_gb	8.0
capacity.system_drive_free_gb	9.2
capacity.system_drive_free_pct	3.6
capacity.system_drive_total_gb	256.0
configuration.baseline_drift_count	13
configuration.baseline_drift_items	SMBv1 enabled, SMB signing not required, TLS 1.0 enabled, TLS 1.1 en..
configuration.baseline_reference	CIS Microsoft Windows 10 Benchmark v3.0
data.retention_policy_configured	False
encryption.disk_encryption_enabled	False
encryption.disk_encryption_type	None
encryption.encryption_percentage	0
encryption.fips_mode	False
encryption.key_protector_present	False
encryption.key_protector_types	(none)
encryption.recovery_key_escrowed	False
encryption.removable_drive_encryption_required	False
encryption.smb_signing_required	False
encryption.smbv1_enabled	True
encryption.ssl30_enabled	True
encryption.tls10_enabled	True
encryption.tls11_enabled	True
encryption.tls12_enabled	True
encryption.tls13_enabled	False
encryption.unencrypted_volume_count	2
encryption.unencrypted_volumes	C:, D:

Parameter	Observed value
endpoint_protection.antivirus_enabled	True
endpoint_protection.antivirus_product	Microsoft Defender Antivirus
endpoint_protection.applocker_or_wdac_enabled	False
endpoint_protection.asr_rules_enabled	0
endpoint_protection.behavior_monitoring	False
endpoint_protection.cloud_protection_enabled	False
endpoint_protection.edr_enabled	False
endpoint_protection.firewall_domain	True
endpoint_protection.firewall_private	False
endpoint_protection.firewall_public	False
endpoint_protection.firewall_rule_count	88
endpoint_protection.inbound_default_block	False
endpoint_protection.last_full_scan_days	190
endpoint_protection.network_protection_enabled	False
endpoint_protection.pua_protection_enabled	False
endpoint_protection.realtime_protection	False
endpoint_protection.screen_lock_timeout_min	60
endpoint_protection.screensaver_password_required	False
endpoint_protection.secure_boot_enabled	False
endpoint_protection.signature_age_days	21
endpoint_protection.signature_version	1.401.220.0
endpoint_protection.tamper_protection	False
endpoint_protection.tpm_present	False
endpoint_protection.tpm_ready	False
endpoint_protection.tpm_version	(not collected)
endpoint_protection.uac_enabled	False
endpoint_protection.usb_storage_blocked	False
hardware.battery_present	True
hardware.chassis_type	10
hardware.disk_count	1
hardware.disk_health_ok	False
identity.accounts_password_never_expires	4
identity.blank_password_accounts	1
identity.credential_guard_enabled	False
identity.default_admin_renamed	False
identity.guest_account_enabled	True
identity.inactive_accounts_90d	3
identity.laps_enabled	False
identity.local_admin_count	7
identity.local_admin_members	WS-FIN-014\Administrator, WS-FIN-014\jsmith, WS-FIN-014\temp-it, CO..
identity.local_user_count	9
identity.lockout_duration_min	0
identity.lockout_threshold	0
identity.lockout_window_min	0
identity.logon_banner_configured	False
identity.mfa_coverage_pct	0
identity.mfa_enabled	False
identity.mfa_providers	(none)
identity.password_complexity_enabled	False
identity.password_history_size	0
identity.password_max_age_days	0

Parameter	Observed value
identity.password_min_age_days	0
identity.password_min_length	6
identity.standard_users_cannot_install	False
logging.audit_account_lockout	No Auditing
logging.audit_account_management	Success
logging.audit_logoff_events	No Auditing
logging.audit_logon_events	No Auditing
logging.audit_object_access	No Auditing
logging.audit_policy_change	No Auditing
logging.audit_privilege_use	No Auditing
logging.audit_process_creation	No Auditing
logging.command_line_auditing	False
logging.log_forwarding_enabled	False
logging.logging_level	Minimal
logging.ntp_server	(not collected)
logging.powershell_module_logging	False
logging.powershell_scriptblock_logging	False
logging.security_log_max_size_mb	20
logging.security_log_record_count	18422
logging.security_log_retention_days	4
logging.siem_agents_detected	(none)
logging.time_offset_seconds	47.8
logging.time_sync_configured	False
metadata.collected_by	CORP\svc-audit
metadata.collected_elevated	True
metadata.collected_utc	2026-08-08T09:14:22Z
metadata.collector_version	1.0.0
metadata.domain	corp.acme.local
metadata.domain_joined	True
metadata.fqdn	ws-fin-014.corp.acme.local
metadata.hostname	WS-FIN-014
metadata.is_server	False
metadata.manufacturer	Dell Inc.
metadata.model	Latitude 7430
metadata.os_build	22H2
metadata.os_caption	Microsoft Windows 10 Pro
metadata.os_version	10.0.19045
metadata.serial_number	SN-8906245
network.anonymous_share_enumeration	True
network.dns_filtering_enabled	False
network.dns_servers	10.10.1.10
network.host_firewall_isolation	False
network.ipv6_enabled	True
network.listening_port_count	7
network.llmnr_disabled	False
network.netbios_enabled	True
network.open_listening_ports	21, 23, 135, 139, 445
network.open_shares	Finance, Public, Temp
network.open_shares_everyone	3
network.rdp_enabled	True
network.rdp_nla_required	False

Parameter	Observed value
network.rdp_port	3389
network.risky_ports_open	21, 23, 135, 139, 445
network.risky_ports_open_count	7

(16 further parameters omitted for brevity.)